HACKER WOMEN COUNCIL

Tecnología · Mujeres · Impacto Global — Ethical Hacking



Nombre completo:	Nelly Guadalupe Lara Hernández
Curso / Programa:	Hacker Women Council · Ethical Hacking
Fecha:	05 de septiembre de 2026

Nota metodológica

Este documento desarrolla los siete puntos solicitados en la actividad, aplicando el rol de un equipo profesional de Ethical Hacking / Penetration Testing sobre el caso de estudio “Aurora Market”: una plataforma de comercio electrónico mexicana que reportó un posible incidente de exposición de información entre cuentas de clientes y contrató una evaluación formal de seguridad.

1. Objetivo del pentest

El objetivo de este pentest no es simplemente cumplir un requisito ni entregar una lista de fallas técnicas: nace directamente del incidente que motivó el proyecto. Una persona del área de atención al cliente recibió el reporte de un usuario que aseguraba haber visto información que aparentemente pertenecía a otra cuenta, y el equipo de tecnología de Aurora Market no pudo determinar si se trató de un error de la aplicación, un problema de permisos, una configuración incorrecta o una vulnerabilidad real explotada por un atacante. Esa incertidumbre es, en sí misma, la razón de ser de esta evaluación: Aurora Market necesita pasar de "no sabemos exactamente qué ocurrió" a "sabemos, con evidencia técnica, qué tan expuesta está nuestra aplicación y por qué".

Concretamente, se busca conocer tres cosas. Primero, si existen actualmente vulnerabilidades explotables en la aplicación web, en particular en los mecanismos de autenticación, gestión de sesiones y control de acceso entre cuentas de clientes, ya que ahí es donde se originó la sospecha del incidente reportado. Segundo, qué impacto real tendría cada vulnerabilidad si un atacante la explotara: qué datos de clientes, de pedidos o del panel administrativo podrían quedar expuestos, y qué tan accesible sería llegar a explotarlas para alguien con un nivel de conocimiento similar al que tendría un atacante externo con pocas credenciales o accesos filtrados. Y tercero, qué tan preparada está la organización para detectar y contener un evento de este tipo, considerando que el incidente fue detectado por un cliente y no por un control interno de Aurora Market, lo cual en sí mismo es una señal a evaluar.

El valor de este pentest para Aurora Market es tanto técnico como de negocio. La empresa almacena información sensible de miles de clientes —nombres, correos, teléfonos, direcciones de envío e historial de compras— y su modelo de negocio depende por completo de que esos clientes confíen en que sus datos y sus compras están seguros. Una evaluación bien ejecutada le permite a Aurora Market, primero, confirmar o descartar con evidencia técnica (y no con suposiciones) si el incidente reportado corresponde a una vulnerabilidad real y, de ser así, cuál es su causa raíz exacta; segundo, anticiparse a un atacante real encontrando y corrigiendo las fallas antes de que deriven en una fuga de datos, pérdidas económicas, daño reputacional o consecuencias legales; y tercero, tomar decisiones de inversión en seguridad basadas en riesgo real y priorizado, en lugar de seguir corrigiendo problemas de forma reactiva conforme van apareciendo, que es como ha operado la empresa hasta ahora. En resumen, el pentest transforma una señal de alerta aislada —el reporte de un solo cliente— en un diagnóstico integral, evidenciado y accionable sobre la seguridad real de la plataforma.

2. Alcance

El alcance delimita con precisión los sistemas que serán evaluados y aquellos que quedan explícitamente excluidos, conforme a la autorización otorgada por Aurora Market.

✓ SÍ SE EVALUARÁ	✕ FUERA DEL ALCANCE
• Aplicación web pública de Aurora Market: registro de cuentas, inicio de sesión, catálogo y búsqueda de productos, carrito de compras, checkout y seguimiento de pedidos.	• Redes sociales oficiales de Aurora Market y las cuentas asociadas a ellas. • Equipos personales y dispositivos de los empleados de Aurora Market.

• Panel administrativo (backoffice) utilizado por el personal interno para gestionar productos, usuarios y pedidos. • APIs y servicios backend que dan soporte a la aplicación web (autenticación, sesiones, consulta y gestión de datos de clientes y pedidos). • Mecanismos de autenticación, autorización y control de acceso entre los distintos tipos de usuario (clientes y personal interno). • Escenario puntual reportado por un cliente: posible exposición de información perteneciente a otra cuenta.	• Cuentas y servidores de correo corporativo del personal. • Proveedores externos e infraestructura de terceros no autorizada explícitamente (pasarelas de pago, hosting, mensajería, etc.). • Cualquier sistema o subdominio no incluido por escrito en el alcance, así como pruebas de denegación de servicio (DoS/DDoS).

3. Autorización y condiciones

Antes de iniciar cualquier prueba técnica, deben quedar formalmente definidos los siguientes permisos y condiciones entre el equipo de Ethical Hacking y Aurora Market:

PERMISOS REQUERIDOS	CONDICIONES ACORDADAS
• Autorización formal por escrito (carta de autorización / Rules of Engagement) firmada por un representante de Aurora Market con potestad para autorizarla. • Acuerdo de confidencialidad (NDA) firmado entre ambas partes. • Credenciales de prueba (cuentas de cliente y, de ser posible, de personal interno) creadas específicamente para el pentest, sin usar datos ni cuentas reales. • Punto de contacto técnico de Aurora Market disponible durante la ejecución para escalar dudas o incidentes. • Canal y protocolo definidos para reportar de inmediato cualquier hallazgo crítico, sin esperar al informe final.	• Las pruebas se realizan únicamente sobre la aplicación web autorizada; queda prohibido atacar redes sociales, equipos personales, correos o proveedores externos. • No se ejecutarán acciones que interrumpan deliberadamente la plataforma ni que afecten información real de clientes. • Las pruebas técnicas se ejecutarán en horarios de menor actividad, previamente acordados con Aurora Market. • Toda vulnerabilidad crítica se comunicará de inmediato al equipo técnico, de forma paralela al informe final. • La colaboración se basa en confianza, transparencia y comunicación constante entre ambos equipos durante todo el proyecto.

4. Tipo de pentest

Tipo de pentest elegido:	Gray-box (caja gris)

☐ BLACK-BOX	☑ GRAY-BOX	☐ WHITE-BOX
El evaluador no tiene conocimiento previo de la infraestructura, código o configuraciones.	*El evaluador tiene información parcial, como credenciales o datos de la aplicación, pero no conoce todos los detalles internos.*	*El evaluador tiene conocimiento completo de la infraestructura, el código fuente y configuraciones.*

Justificación de la elección

Según la información compartida por Aurora Market en la etapa de planificación, el equipo evaluador no parte de cero, como ocurriría en un escenario black-box, ni cuenta tampoco con acceso completo al código fuente, la arquitectura y las configuraciones internas, como correspondería a un escenario white-box. Aurora Market entregó información parcial: se sabe que existe una aplicación web, una base de datos, mecanismos de autenticación y distintos tipos de usuario (clientes y personal interno), pero no se compartieron detalles técnicos completos sobre tecnologías, arquitectura ni código fuente.

Este nivel de conocimiento parcial, normalmente acompañado de credenciales de prueba para simular usuarios legítimos, corresponde exactamente a la definición de un pentest gray-box. Este enfoque es además el más adecuado para este caso concreto: permite evaluar tanto los riesgos que enfrentaría un atacante externo como los riesgos derivados de un posible abuso de privilegios o de fallas de control de acceso entre cuentas —que es justamente el tipo de incidente reportado por el cliente— sin necesidad de acceso al código fuente, y resulta más eficiente en tiempo que un enfoque black-box puro, ya que permite enfocar los esfuerzos en los módulos de negocio más relevantes (cuentas, pedidos y panel administrativo).

5. Planificación

Antes de iniciar la parte técnica, el equipo debe completar los siguientes elementos clave de planificación:

- **Objetivos:** confirmar y documentar por escrito lo definido en el punto 1 —entender la causa del incidente reportado, dimensionar el riesgo real de negocio e informar de forma accionable a Aurora Market.
- **Alcance:** delimitar por escrito los activos incluidos (aplicación web, panel administrativo y APIs asociadas) y excluidos (redes sociales, equipos personales, correo corporativo y proveedores externos), conforme al punto 2, y hacerlo firmar por Aurora Market.
- **Permisos y condiciones:** formalizar la autorización escrita, el NDA, las credenciales de prueba y las reglas de comportamiento (sin pruebas destructivas, sin afectar datos reales, horarios de menor actividad), conforme al punto 3.
- **Metodología a utilizar:** documentar el marco de referencia que guiará la evaluación —OWASP Web Security Testing Guide (WSTG) combinado con el PTES— definiendo las categorías de prueba aplicables a autenticación, control de acceso y gestión de pedidos.

Recopilación de información previa

Antes de iniciar las pruebas técnicas, el equipo combina dos tipos de fuentes. Por un lado, fuentes internas: la información que Aurora Market entregó formalmente en el encargo (URLs de los entornos autorizados, credenciales de prueba para el rol de cliente y, si se otorgan, para el rol de personal interno, y el contexto puntual del incidente —en qué módulo el cliente vio información de otra cuenta—). Por otro lado, fuentes abiertas (OSINT), necesarias porque Aurora Market no entregó documentación técnica completa de su arquitectura: búsqueda en motores de búsqueda (Google dorking) sobre el dominio autorizado, revisión del sitio público, consulta de WHOIS y análisis de registros DNS (subdominios y proveedores asociados dentro del alcance), y una revisión únicamente informativa de las redes sociales oficiales de Aurora Market para obtener contexto de la empresa, sin interactuar con ellas por estar fuera de alcance. Esta combinación de recolección pasiva (no genera tráfico hacia los sistemas de Aurora Market) y recolección activa controlada (si interactúa con la aplicación autorizada) permite construir un mapa inicial de la superficie de ataque sin comprometer la disponibilidad de la plataforma.

En cuanto a herramientas: se utilizaría Nmap para el reconocimiento activo de puertos y servicios expuestos por la infraestructura autorizada (se detalla en la fase de Reconocimiento), y OWASP ZAP (Zed Attack Proxy) como proxy de interceptación y escáner de vulnerabilidades web —permite navegar la aplicación autenticada con las credenciales de prueba, mapear todos los endpoints y parámetros disponibles (spidering) e identificar de forma automatizada problemas comunes como cabeceras de seguridad ausentes, cookies mal configuradas o parámetros potencialmente inyectables, que después se validan manualmente—. A esto se sumaría Burp Suite (Community o Professional) para interceptar y modificar manualmente las peticiones HTTP, indispensable para probar fallas de control de acceso como la reportada por el cliente (tipo IDOR), ya que se necesita alterar identificadores de objetos —por ejemplo el ID de un pedido, una dirección o una cuenta— dentro de una solicitud autenticada y observar si el servidor responde con datos que no deberían pertenecer a ese usuario.

Recursos necesarios

Definir el equipo y sus roles, el entorno y herramientas a usar (Nmap, OWASP ZAP, Burp Suite, cuentas de prueba dedicadas para cada rol de usuario) y el tiempo estimado por fase.

Programación del pentest: horario propuesto

Dado que Aurora Market pidió expresamente que las pruebas se realicen en horarios de menor actividad para minimizar el impacto sobre sus operaciones, se propone ejecutar las pruebas activas (escaneo de puertos, spidering autenticado y pruebas de explotación controlada) en la franja de 11:00 p. m. a 5:00 a. m., de martes a jueves. Se elige ese rango porque, en un e-commerce como Aurora Market, el tráfico de clientes reales suele concentrarse en las tardes y primeras horas de la noche, así como los fines de semana y los días de quincena; realizar las pruebas de madrugada entre semana reduce la probabilidad de coincidir con clientes navegando o comprando y minimiza el riesgo de que una prueba se confunda con una caída real del servicio. Por esa misma razón se descartan fines de semana, quincenas y fechas de campañas u ofertas conocidas. Las actividades puramente pasivas (OSINT, WHOIS, análisis de DNS) sí pueden ejecutarse en cualquier horario, ya que no generan tráfico hacia los sistemas de Aurora Market ni representan riesgo operativo. Todo el cronograma —fechas de inicio y fin, estas ventanas horarias y los hitos de comunicación de avances— se documenta y se acuerda por escrito con Aurora Market antes de comenzar.

6. Fases del pentest

Esta actividad corresponde a la etapa de análisis y planificación, previa a la ejecución real del pentest: todavía no se corre ninguna herramienta ni se explota nada. Lo que se explica a continuación, fase por fase, es el razonamiento técnico aplicado al caso de Aurora Market —qué se haría, con qué herramienta y con qué propósito— para justificar cómo se abordaría cada etapa una vez autorizada la ejecución.

1. Reconocimiento: en esta fase no se ejecuta ninguna prueba de intrusión; el objetivo es construir el mapa completo de la superficie de ataque autorizada antes de decidir dónde enfocar el análisis de vulnerabilidades. Se combina reconocimiento pasivo —búsqueda en motores de búsqueda sobre el dominio autorizado, revisión pública del sitio, consulta de WHOIS y análisis de registros DNS (subdominios y proveedores asociados)— con reconocimiento activo sobre la infraestructura ya autorizada. En este último sí sería necesario un análisis de puertos: antes de examinar la aplicación en detalle hace falta confirmar qué servicios están expuestos hacia internet —por ejemplo, si solo está abierto el puerto 443/HTTPS de la aplicación o si además hay puertos de administración, bases de datos u otros paneles accesibles indebidamente, lo cual sería en sí mismo un hallazgo—. Para esto se utilizaría Nmap, con un escaneo de descubrimiento de puertos TCP y detección de servicios y versiones (-sV), que entrega el listado de puertos abiertos, el servicio corriendo en cada uno y su versión de software; esa información es clave para detectar servicios innecesariamente expuestos y posibles vulnerabilidades conocidas asociadas a esas versiones. Se complementa con fingerprinting de la aplicación web (encabezados HTTP, cookies, mensajes de error) para identificar el framework o tecnología de backend, y un spidering inicial con OWASP ZAP para mapear rutas, formularios y parámetros en los distintos roles de usuario (cliente y personal interno) que Aurora Market mencionó. Antes de avanzar a la siguiente fase, el equipo debe tener claro qué servicios y puertos están expuestos, el mapa completo de endpoints y flujos (registro, login, carrito, checkout, pedidos, panel administrativo), las tecnologías que los soportan y, sobre todo, cuáles son los posibles puntos de entrada más relevantes para el caso puntual reportado: en particular, cualquier endpoint donde el usuario autenticado consulta o modifica datos referenciando un identificador (de cuenta, pedido o dirección), que es donde se concentrará el análisis de control de acceso en la siguiente fase.

2. Análisis de vulnerabilidades: con el mapa de la aplicación obtenido en el reconocimiento y las credenciales de prueba proporcionadas, se utilizaría OWASP ZAP (o Burp Suite) en modo de escaneo activo autenticado para identificar de forma automatizada vulnerabilidades comunes del OWASP Top 10 (inyección, configuraciones inseguras, exposición de datos sensibles, componentes vulnerables conocidos) sobre los endpoints mapeados; el propósito de la herramienta aquí es obtener una primera lista priorizada de posibles debilidades y reducir el tiempo de análisis manual, sabiendo que sus resultados siempre se validan a mano porque puede generar falsos positivos. Como el incidente que originó el proyecto es la posible exposición de información entre cuentas, el análisis se enfocaría además de forma manual y dirigida en pruebas de control de acceso: usando el proxy de interceptación (Burp Suite/OWASP ZAP) se repetirían solicitudes autenticadas modificando identificadores de recursos —el ID de un pedido, una dirección o un usuario, en la URL o en el cuerpo de la petición— para verificar si el servidor entrega información de otra cuenta sin validar correctamente la autorización (fallas tipo IDOR). También se revisarían los tokens de sesión con ayuda del mismo proxy, para ver si son predecibles, si expiran correctamente o si pueden reutilizarse entre cuentas. Se sumaría Nikto como escáner complementario del servidor web, para identificar configuraciones inseguras conocidas (archivos expuestos, cabeceras de seguridad faltantes, métodos HTTP innecesarios habilitados). Lo que se busca obtener en esta fase es concreto: qué endpoints permiten acceso no autorizado

a datos de otra cuenta, qué tan grave es esa exposición (datos personales, historial de compras) y qué tan fácil sería para un atacante con un conocimiento similar al del equipo (gray-box) reproducir el hallazgo —justo lo necesario para confirmar o descartar la causa del incidente original.

3. Explotación: validar de forma controlada y no destructiva las vulnerabilidades identificadas, confirmando si es posible acceder a información de otra cuenta —replicando y determinando la causa raíz del incidente reportado por el cliente—, evitando en todo momento modificar, eliminar o exponer datos reales, y documentando evidencia (capturas, solicitudes y respuestas) de cada hallazgo confirmado.
4. Post-explotación: determinar el alcance real del impacto de cada vulnerabilidad confirmada —qué información pudo quedar expuesta (datos personales, historial de compras), si es posible escalar desde una cuenta de cliente hacia el panel administrativo, y qué tan persistente o replicable sería un acceso no autorizado—, siempre dentro del entorno autorizado y sin afectar la operación del negocio.
5. Informe: documentar cada hallazgo con descripción técnica, evidencia, nivel de riesgo (por ejemplo con CVSS), módulos afectados y recomendaciones de remediación específicas. Se entrega un informe técnico detallado para el equipo de desarrollo y un resumen ejecutivo para la dirección, incluyendo la explicación del incidente original que dio origen al proyecto y las medidas para prevenir casos similares.

7. Investigación

Metodología elegida:	OWASP Web Security Testing Guide (WSTG), complementada con el PTES

¿Por qué sería útil para este proyecto?

El OWASP WSTG es una metodología especializada y de referencia mundial para evaluar la seguridad de aplicaciones web, y cubre en detalle las categorías de prueba más relevantes para Aurora Market: autenticación, gestión de sesiones y, en particular, pruebas de autorización y control de acceso (como los defectos tipo IDOR), directamente aplicables al incidente reportado por el cliente que vio información de otra cuenta.

Al ser una metodología abierta, estructurada por categorías y ampliamente adoptada en la industria, permite al equipo cubrir sistemáticamente toda la superficie de la aplicación sin omitir áreas críticas, y facilita la comunicación de los resultados con el equipo de desarrollo de Aurora Market, que probablemente también la conoce o puede consultarla. Complementarla con el PTES (Penetration Testing Execution Standard) aporta una estructura clara para las fases de planificación, recolección de información, modelado de amenazas y generación de informes, alineándose con la interacción real que tendrá el equipo con Aurora Market en materia de autorización, comunicación y entrega de resultados.